

CONTENTS

- Overview
- 1 The Governance Gap: Why AI Needs a Management System
- 2 ISO 42001: An AI Management System Built on ISO 27001's Foundation
- 3 The Plan-Do-Check-Act Cycle and Risk-Based Thinking
- 4 Four Layers of AI Risk: Data, Model, System, and Usage
- 5 Context and Leadership: Scoping AI and Assigning Ownership
- 6 Planning, Support, Operation, Evaluation, and Improvement
- 7 Comparing ISO 42001, NIST AI RMF, and the EU AI Act
- 8 Complementary Layers: Building a Resilient AI Governance Stack
- Glossary
- Check yourself
- Where to go next

ISO 42001: A Management System for Governing AI Risk

Understand how ISO 42001's plan-do-check-act cycle, four risk layers, and high-level structure govern AI, and how it fits alongside the NIST AI RMF and the EU AI Act.

For security, compliance, and engineering leaders who need to figure out how to govern AI systems their organization builds or buys · 27 July 2026

[Watch the source video](#)

[Read the condensed version](#)

[Read the highlights](#)

BEFORE YOU START

- General familiarity with organizational risk or compliance programs, such as what an information security management system (ISMS) does

Overview

When an AI system denies a loan, screens a resume, or blocks a transaction, someone eventually has to answer for that decision: who validated the model, who is watching it now, and who is responsible if it is wrong. Most organizations do not have a clean answer, and that gap is exactly what AI governance frameworks exist to close.

ISO/IEC 42001 is the newest attempt to formalize that answer. It extends the same "management system" idea that ISO 27001 uses for information security into the AI domain: a continuous, auditable, certifiable process, built on plan-do-check-act, for managing AI risk across a system's full life cycle. It organizes that work around four layers of risk (data, model, system, usage) and a standard seven-section structure (context, leadership, planning, support, operation, evaluation, improvement).

ISO 42001 is not the only option on the table. The U.S. NIST AI Risk Management Framework offers voluntary best-practice guidance, and the EU AI Act imposes binding legal obligations tiered by risk. This lesson walks through what ISO 42001 actually requires, how its risk model works, and how it fits alongside NIST and the EU AI Act rather than competing with them.

KEY TAKEAWAYS

- ✓ ISO 42001 is the AI-specific counterpart to ISO 27001: a certifiable management system for governing AI risk continuously, not a one-time checklist.
- ✓ ISO 42001 runs on the plan-do-check-act cycle: define AI policy and risk criteria, deploy with controls, monitor for bias and drift, then act on what you find.
- ✓ AI risk shows up in four distinct layers, data, model, system, and usage, and a control aimed at one layer does not fix the others.
- ✓ ISO 42001 follows the standard ISO high-level structure, with sections for context, leadership, planning, support, operation, evaluation, and improvement.
- ✓ The NIST AI Risk Management Framework is voluntary guidance describing what good AI risk management looks like; it has no certification mechanism.
- ✓ The EU AI Act is binding law with a tiered risk structure (unacceptable, high, limited, minimal) and enforceable penalties for noncompliance.
- ✓ NIST, ISO 42001, and the EU AI Act are complementary layers, not competing choices: risk-modeling guidance, certifiable governance, and legal compliance each cover a different need.
- ✓ Treating AI governance as a one-time checkbox, or skipping it entirely, both leave an accountability gap; building it into an ongoing management system is what lets AI scale safely.

01 The Governance Gap: Why AI Needs a Management System

0:00

When an algorithm denies a loan with no explanation and no accountable owner, that is a governance failure, not just a technology failure.

Picture a bank's AI system denying a loan application. There is no explanation offered to the applicant and no appeal process. Now ask three questions: who validated that model before it went live, who has been monitoring it since, and who is responsible if it turns out to be wrong. Most organizations deploying AI cannot answer all three, and that is the gap this lesson is about.

This is not primarily an ethics problem, it is an operational one. When a regulator, a customer, or a court eventually asks those same three questions, "the model just does that" is not an answer. An organization needs a defined, repeatable process for validating, monitoring, and taking responsibility for its AI systems, the same way it already has a defined process for handling security incidents or financial reporting.

That defined, repeatable process is what a "management system" means in this context: not a single tool, dashboard, or one-time model audit, but an ongoing cycle of planning, executing, checking, and improving that an organization runs continuously around its AI systems.

KEY POINTS

- An AI decision with no named owner is a liability: nobody can answer for it during an audit, a complaint, or a regulatory inquiry.
- Three questions expose the gap in most organizations: who validated the model, who monitors it in production, who is accountable when it fails.
- A management system is a defined process, plan, execute, monitor, improve, not a single tool or a one-time model check.
- The goal is to make AI governance a standing operational capability rather than a project that ends at launch.

The unexplained loan denial

A bank's AI denies a loan application with no explanation and no appeal. A governed version of the same system would have a documented validation report signed off before launch, a named model owner who can be reached with questions, a monitoring dashboard tracking approval rates by applicant group, and a defined process for the applicant to appeal and for a human to review the case. None of those require a different model, they require a management system around the model.

02 ISO 42001: An AI Management System Built on ISO 27001's Foundation

0:44

ISO 42001 applies the same management-system concept that ISO 27001 uses for information security, but aimed at AI risk instead.

ISO 27001 is the international standard for information security management systems (ISMS). It specifies how an organization establishes, implements, maintains, and continuously improves a system for managing security risk. It does not tell you which firewall vendor to buy, it tells you how to run the ongoing process of managing security.

ISO 42001 does the same thing for AI. It defines an AI management system (AIMS): a continuous, auditable, certifiable process built around continual improvement across an AI system's entire life cycle, from design through decommissioning. It is explicitly not a fixed checklist of technical controls to tick off once.

The key distinction to hold onto is that ISO 42001 is governance, not model architecture. It does not specify which algorithm, model family, or vendor to use. It specifies how an organization manages the risk around whatever AI it chooses to build or buy, who owns it, how it is assessed, how it is monitored, and how findings feed back into the process.

KEY POINTS

- ISO 27001 governs information security; ISO 42001 applies the same management-system concept to AI risk.
- A management system standard specifies an ongoing process, establish, implement, maintain, improve, not a fixed list of technical controls.
- ISO 42001 is auditable and certifiable: an external party can assess an organization against it and issue a certificate.
- Governance, not architecture: 42001 does not dictate which model or algorithm to use, it dictates how the risk around that AI is managed.

27001 vs 42001 side by side

The two standards share a structure and philosophy but differ in what they manage. Lining them up side by side makes the parallel concrete.

ISO 27001

Manages information security risk
Produces an ISMS
Certifiable, auditable
Focus: confidentiality, integrity, availability of information

ISO 42001

Manages AI risk
Produces an AIMS
Certifiable, auditable
Focus: AI risk across data, model, system, and usage layers

03 The Plan-Do-Check-Act Cycle and Risk-Based Thinking

1:25

ISO 42001 runs on plan-do-check-act, a repeating cycle, and scales its controls to how much risk a given AI system actually poses.

Like other ISO management-system standards, ISO 42001 follows the plan-do-check-act (PDCA) model. In the plan phase, the organization defines AI policies, the scope of which systems are covered, and its risk criteria. In the do phase, it develops and deploys AI systems with the controls the plan called for. In the check phase, it monitors live performance, watching for bias, drift, and unintended consequences. In the act phase, it takes what it found and feeds it back into policy and controls, closing the loop.

The important part is that this is a cycle, not a project with an end date. Check happens continuously after deployment, not just once before launch, because a model that was fair and accurate on day one can behave differently as the data it sees in production shifts.

Everything in ISO 42001 also hinges on a risk-based approach: not all risk is equal, because not all systems are equal. A chatbot that suggests restaurant names poses a different level of risk than a system that screens loan applications, so the plan should size its controls to match the level of risk a given system actually poses, rather than applying the same heavy process everywhere.

KEY POINTS

- Plan: set AI policy, define scope, and define risk criteria before building anything.
- Do: build and deploy the AI system with the controls the plan called for.
- Check: monitor live performance for bias, drift, and unintended consequences on an ongoing basis, not as a one-time test.
- Act: fold findings back into policy and controls, closing the loop.
- Because risk is not uniform across systems, controls should scale to the level of risk a given AI system poses.

PDCA applied to a hiring-screening AI

A company deploying a resume-screening model can walk the same four phases: plan a fairness policy stating no automated rejection without human review near the decision threshold, do by deploying the model behind a review queue with logging, check by tracking selection rates by demographic group every month, and act by adjusting the threshold or retraining if a disparity shows up.

```
PLAN  -> policy: no automated reject without human review near threshold
DO    -> deploy: model + review queue + decision logging
CHECK -> monitor: selection rate by group, monthly drift report
ACT   -> respond: retrain or adjust threshold if disparity is found
```

04 Four Layers of AI Risk: Data, Model, System, and Usage

2:12

ISO 42001 splits AI risk into four layers, and a control that fixes one layer does not automatically fix the others.

ISO 42001 explicitly considers risk across multiple layers rather than treating "AI risk" as one undifferentiated thing. Data risk covers bias or quality issues in the underlying data that will skew results before a model ever runs. Model risk covers the accuracy of the model's outputs and their explainability, whether you can say why the model produced a given result. System risk covers everything around the model itself: how components integrate, and the security of the system as a whole. Usage risk covers what happens after deployment, misuse and unintended consequences introduced by how people actually use the system.

Separating these layers matters because they call for different fixes. A model can be highly accurate and well-secured and still cause harm if people use it in ways it was never designed for, that is a usage problem, not a model problem. Conversely, a model trained on biased data will produce biased results no matter how secure the surrounding system is, that is a data problem, not a system problem.

A useful habit is to ask, for any AI incident, which of the four layers it actually traces back to, before deciding what to fix.

KEY POINTS

- Data risk: biased or low-quality training or input data skews outcomes before the model ever runs.
- Model risk: the model's accuracy and its explainability, whether an output can be justified, are both in scope.
- System risk: risk from how components integrate and how the overall system is secured.
- Usage risk: even an accurate, secure model can be misused or produce unintended consequences once deployed.
- Controls should target the layer actually at fault; a bias problem in the data is not fixed by tightening system security.

Four layers applied to the loan-denial AI

Revisiting the loan-denial example from the first section through each layer: data (was the training data representative of the full applicant population), model (can a denial be explained in terms a loan officer or applicant can understand), system (is the credit-bureau integration secure and reliable), usage (are loan officers overriding the model's recommendation in ways that reintroduce the bias it was designed to avoid).

05 Context and Leadership: Scoping AI and Assigning Ownership

2:59

ISO 42001 opens by defining which AI systems are in scope and naming who is accountable for them; without an owner, nothing else in the standard happens.

ISO 42001 uses the standard ISO high-level structure, a common section skeleton shared across ISO management-system standards, which is part of why an organization already running ISO 27001 can extend that existing structure into AI rather than starting from nothing.

The first section is context. Here the organization defines the scope of the AI systems being governed, identifies stakeholders, and determines whatever regulatory obligations apply, which vary by industry and by country. Scope matters because "govern all our AI" is too vague to act on; a workable AIMS names which systems, teams, and data are actually covered.

The second section is leadership. Here the organization assigns AI accountability, decides who is responsible, because if no one is, the work does not get done. Leadership also defines the AI policy itself and establishes the governance structure, committees, reporting lines, decision rights, that the rest of the system runs on.

KEY POINTS

- Context: scope which AI systems are covered, identify stakeholders, and determine which regulations apply, which varies by industry and jurisdiction.
- Leadership: name an accountable owner for AI risk; without a named owner, the work does not happen.
- Leadership also produces the AI policy and the governance structure the rest of the system depends on.
- The ISO high-level structure lets an organization with an existing ISO 27001 program extend it rather than build AI governance from scratch.

Naming an accountable owner

A company deploying a customer-service chatbot names a head of AI risk as the accountable owner within the leadership section of its AIMS. That person signs off on the AI policy, chairs a review before any new model is deployed, and is the named point of contact when the check phase turns up a problem.

06 Planning, Support, Operation, Evaluation, and Improvement

3:44

The remaining five sections of ISO 42001 turn risk assessment and policy into day-to-day operating practice, and close the loop when something goes wrong.

Planning is where AI risk assessments happen: choosing a methodology, deciding the organization's risk appetite and tolerance, and building a risk treatment plan. Not every risk gets eliminated, in some cases the documented decision is to accept a risk, and that is a valid outcome as long as it is deliberate and recorded. Planning also sets measurable AI objectives, so later evaluation has something concrete to check against.

Support covers the enablement work: documentation, awareness training, and communication of how the organization actually wants the system operated. A policy nobody has read does not govern anything.

Operation defines life-cycle governance and change management, because an AI system will not stay the same, models drift, data changes, vendors update their APIs, so change is the only constant. Operation also covers oversight of AI supplied by third parties. Evaluation is where the organization monitors continuously, runs internal audits, and holds management reviews, rather than relying on a single sign-off

at launch. Improvement is where incidents get handled, corrective actions get taken, and lessons get fed back into planning, this is what closes the act phase of the PDCA loop and makes the whole system continuous rather than a one-time project.

KEY POINTS

- Planning: run a defined risk-assessment methodology and set risk appetite, tolerance, and a treatment plan; accepting a risk is a valid, documented outcome.
- Planning also sets measurable AI objectives so evaluation has something concrete to check against later.
- Support: provide the documentation, training, and communication needed to actually run the system.
- Operation: govern the AI system's life cycle, including change management and oversight of third-party or vendor AI.
- Evaluation: monitor continuously, run internal audits, and hold management reviews rather than a single launch-time check.
- Improvement: handle incidents and corrective actions and feed the lessons back into planning, closing the PDCA loop.

Supplier oversight for a vendor-supplied model

A company embeds a third-party large language model API into its product. Under operation-phase supplier oversight, it tracks the vendor's model version changes, requires advance notice before the vendor swaps the underlying model, and re-runs its evaluation suite after any upgrade, treating a vendor's silent model change the same way it would treat any other change to a system it operates.

07 Comparing ISO 42001, NIST AI RMF, and the EU AI Act

5:53

NIST offers voluntary guidance, ISO 42001 offers a certifiable governance system, and the EU AI Act is enforceable law; they answer different questions.

ISO 42001 is not the only AI governance framework in circulation. The U.S. National Institute of Standards and Technology publishes an AI Risk Management Framework (AI RMF), and the European Union has the EU AI Act. Each overlaps with ISO 42001 in subject matter but plays a different role.

The NIST AI RMF is voluntary: an organization can adopt it or not. It is flexible, leaving a good deal of the how up to the user, and functions more as guidance, a design guide describing what good AI risk management looks like, than as a structure to be audited against. There is no certificate to earn at the end of it.

ISO 42001, by contrast, is certifiable. An organization can have an external auditor assess it against the standard and issue a certificate proving compliance, something not possible with NIST's framework. It is also more prescriptive, it lays out a specific structure and tells an organization how to manage its AI infrastructure and meet its obligations consistently.

The EU AI Act is different again: it is law, not a voluntary framework, and it has teeth. It is not optional for organizations operating in the EU. It uses a tiered risk structure, and it is enforced, with penalties for noncompliance. Put simply, the NIST AI RMF is for risk modeling and best practices, ISO 42001 is for governance, auditability, and certification, and the EU AI Act is the legal constraint an organization has to satisfy.

KEY POINTS

- The NIST AI RMF is voluntary guidance, a design guide describing what good AI risk management looks like, with no certification available.
- ISO 42001 is certifiable: an external auditor can assess an organization and issue a certificate, and it prescribes a specific structure to follow.
- The EU AI Act is binding law with a tiered risk structure and enforceable penalties for noncompliance.
- NIST tells you what good risk management looks like, ISO 42001 tells you how to build and prove a governance system, the EU AI Act tells you what you are legally required to do.
- An organization operating in the EU may need all three at once: NIST for risk-modeling practice, ISO 42001 to build and certify governance, the EU AI Act because it is the law.

Risk tiers named under the EU AI Act

The video names four EU AI Act risk tiers, listed from most to least severe. Where a given AI system falls determines the compliance obligations that apply to it.

Unacceptable risk
High risk
Limited risk
Minimal risk

NIST, ISO 42001, and the EU AI Act stack rather than compete, and organizations that build governance into an ongoing system scale AI faster and more safely than those that treat it as a checkbox or skip it entirely.

The three frameworks covered in this lesson are not competing options to choose between, they are complementary layers that reinforce each other: best-practice guidance from NIST, a certifiable management system from ISO 42001, and a binding legal floor from the EU AI Act.

Organizations that treat AI governance as a one-time checkbox, a review completed before launch and never revisited, get the appearance of compliance without the substance; problems like bias drift still surface later, just later than they should have been caught. Organizations that skip governance entirely fare even worse, they still face the same accountability gap described at the start of this lesson, they have just delayed discovering it. Organizations that build governance into an ongoing management system, running the PDCA cycle continuously rather than as a project, are the ones that can scale their AI use faster and more safely, because problems get caught in the check phase instead of in a lawsuit or a regulator's inquiry.

ISO 42001 is notable as the first international standard to formalize AI governance into one complete, certifiable system. Govern AI well and an organization can harness it to do genuinely useful things; fail to govern it, and the closing image from the video is apt, it is like being locked in the trunk while the AI goes for a joy ride: you are along for the ride, but you are not the one steering.

KEY POINTS

- The three frameworks stack rather than compete: best-practice guidance (NIST), a certifiable management system (ISO 42001), and binding law (EU AI Act) each cover a different need.
- Checkbox governance, a one-time review before launch, produces the appearance of compliance without the substance; problems still surface later.
- Skipping governance entirely does not remove the accountability gap from section one, it just delays discovering it.
- Building governance into an ongoing management system, rather than a one-time project, is what lets an organization scale AI use safely.
- ISO 42001 is the first international standard to formalize AI governance into one complete, certifiable system.

Checkbox governance vs. system governance

Company A completes a one-time AI ethics review before launch and never revisits it; six months later a drift issue goes unnoticed because nothing is actively monitoring for it. Company B runs the ISO 42001 PDCA loop, catches the same kind of drift in a routine monthly check, and corrects it before it affects customers. The model in both companies could be identical, the difference is entirely the management system around it.

Glossary

ISO 27001

The international standard for information security management systems (ISMS); it specifies how an organization establishes, implements, maintains, and continually improves a program for managing security risk.

ISO 42001

The international standard for AI management systems (AIMS), the AI-focused counterpart to ISO 27001; it is auditable, certifiable, and built around continual improvement across an AI system's life cycle.

Management system (ISO sense)

A defined, repeatable organizational process, establish, implement, maintain, improve, for running and governing a capability, as opposed to a fixed one-time checklist.

Plan-Do-Check-Act (PDCA)

A four-stage continuous improvement cycle: plan controls and policy, execute them, check the results against real-world performance, then act on what was found.

ISO High-Level Structure (HLS)

The common section skeleton, context, leadership, planning, support, operation, evaluation, improvement, shared across ISO management-system standards so they can be run together.

Bias drift

Gradual change in a model's fairness or accuracy characteristics over time as real-world data shifts away from what the model was trained or validated on.

Explainability

The degree to which a model's output can be understood or justified in terms a human can follow, part of ISO 42001's model-risk layer.

Risk appetite and risk tolerance

Risk appetite is the amount and type of risk an organization is willing to pursue to reach its objectives; risk tolerance is the acceptable variation in outcomes it can withstand for a given risk.

Risk treatment plan

A documented decision for how each identified risk will be handled, mitigate, accept, transfer, or avoid, rather than an assumption that every risk must be eliminated.

NIST AI Risk Management Framework (AI RMF)

A voluntary framework from the U.S. National Institute of Standards and Technology offering flexible, non-certifiable guidance on what good AI risk management practice looks like.

EU AI Act

Binding European Union law regulating AI systems, using a tiered risk structure (unacceptable, high, limited, minimal) and carrying enforceable penalties for noncompliance.

Check yourself

Answer first, then open each one.

Why is ISO 42001 described as "governance, not model architecture"?

Because it does not specify which algorithm or model type to build; it specifies the process an organization runs around whatever AI it deploys, assigning ownership, assessing risk, monitoring, and improving. The specific architecture choice is out of scope; the management process around it is the point.

A company's AI model is highly accurate and its infrastructure is secure, but employees are using it in ways that were never intended. Which of ISO 42001's risk layers does this fall under, and why doesn't fixing the model's accuracy address it?

Usage risk. Data risk and model risk concern the training data and the model's own outputs, and system risk concerns integration and security; none of those cover how people actually use the deployed system once it is live, so improving accuracy or security leaves usage risk untouched.

Under ISO 42001's planning section, is it acceptable for an organization to identify a risk and decide to simply accept it rather than mitigate it?

Yes. The standard does not require eliminating every risk; a documented decision to accept a risk, based on the organization's stated risk appetite and tolerance, is a valid outcome of the risk treatment plan.

Why can't the NIST AI Risk Management Framework be used the same way as ISO 42001 if a company needs to prove compliance to a customer or regulator?

NIST's framework is voluntary guidance with no certification mechanism, it describes what good practice looks like but there is no audit or certificate attached. ISO 42001 is certifiable: an external auditor can assess the organization and issue a certificate that serves as documented proof.

Why are ISO 42001, the NIST AI RMF, and the EU AI Act described as "complementary layers" rather than alternatives to choose between?

Each addresses a need the others don't cover: NIST offers best-practice risk-modeling guidance, ISO 42001 provides a certifiable governance system, and the EU AI Act supplies the binding legal requirement. An organization operating in the EU still has to satisfy the law even if it has also certified to ISO 42001.

The PDCA cycle's "check" phase involves monitoring for bias and drift after deployment. Why isn't a one-time pre-launch validation enough on its own?

Because AI systems and the data they encounter change after launch. The check phase exists precisely because performance, bias, and unintended consequences can emerge or worsen over time, which a single pre-launch test cannot catch.

Where to go next

- Read the ISO/IEC 42001:2023 standard text, or a certification body's summary of it, to see the full control set behind each high-level-structure clause.
- Read the NIST AI Risk Management Framework (AI RMF 1.0) and its accompanying Playbook for concrete voluntary practices to adopt.
- Read the EU AI Act's official risk-tier annexes to see which categories of AI systems fall into unacceptable, high, limited, and minimal risk.
- Compare ISO 27001's clause structure side by side with ISO 42001's to see how an organization already certified to 27001 can extend its existing ISMS into an AIMS.
- Look up a published ISO 42001 certification case study to see what evidence auditors actually check in practice.

Lesson generated from a YouTube transcript with YouTube Lesson Builder.

Explanations are AI-generated. Check anything you intend to rely on.